

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ  
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ  
«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»

**О Т З Ы В**  
**РУКОВОДИТЕЛЯ УЧЕБНОЙ ПРАКТИКИ**

|                                            |                                                                                                                          |
|--------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| Обучающийся                                | Чан Бао Линь                                                                                                             |
|                                            | (Фамилия, И.О.)                                                                                                          |
| Факультет                                  | Безопасности информационных технологий                                                                                   |
| Структурное подразделение                  | ФБИТ                      Группа                      N3446                                                              |
| Направление (специальность)                | 10.03.01 Технологии защиты информации                                                                                    |
| Место прохождения практики<br>Киберполигон | Университет ИТМО, учебно-практический центр -                                                                            |
| Должность практиканта                      | Практикант                                                                                                               |
| Тема индивидуального задания               | Анализ логических ошибок контроля доступа и разработка сценариев тестирования в условиях соревнований Attack-Defense CTF |

**Оценка достигнутых результатов**

| №<br>п/п | Планируемые результаты обучения (показатели)                                                                                           | Оценка |   |   |   |
|----------|----------------------------------------------------------------------------------------------------------------------------------------|--------|---|---|---|
|          |                                                                                                                                        | 5      | 4 | 3 | 2 |
| 1.       | Понимание формата Attack-Defense CTF: раунды, чекер/флаги, статусы OK/MUMBLE/CORRUPT/DOWN, SLA (краткое описание в отчёте).            | +      |   |   |   |
| 2.       | Умение выделять и описывать модель угроз для сервиса и риски утечки частных данных (флагов).                                           |        | + |   |   |
| 3.       | Умение анализировать поверхность атаки сервиса: ключевые эндпоинты, входные параметры, сессии/куки.                                    |        | + |   |   |
| 4.       | Умение различать аутентификацию и авторизацию и находить точки проверок прав доступа в коде/логике.                                    | +      |   |   |   |
| 5.       | Выявление логических ошибок контроля доступа (несоответствие ownership/ролей, неконсистентные проверки, IDOR-классы) и их последствий. | +      |   |   |   |
| 6.       | Разработка тест-сценариев контроля доступа (positive/negative/edge) с критериями pass/fail.                                            |        | + |   |   |
| 7.       | Формирование тест-матрицы (покрытие: роли/объекты/операции/ожидаемый результат).                                                       |        | + |   |   |

|                        |                                                                                                               |   |  |  |  |
|------------------------|---------------------------------------------------------------------------------------------------------------|---|--|--|--|
| 8.                     | Проведение тестирования на стенде и фиксация результатов (ответы сервиса, логи/артефакты, таблица pass/fail). | + |  |  |  |
| 9.                     | Подготовка рекомендаций по устранению выявленных дефектов и оценка влияния на работоспособность (SLA-риски).  | + |  |  |  |
| 10.                    | Выполнение валидации (повторные проверки ключевых сценариев) и оформление итогового отчёта по ГОСТ.           | + |  |  |  |
| <b>Итоговая оценка</b> |                                                                                                               |   |  |  |  |

Руководитель практики от Университета ИТМО \_\_\_\_\_ / \_Менщиков А.А.\_\_\_\_\_  
 (подпись руководителя) Ф.И.О.